LABORATUVAR 5 · GENEL SÜRÜM · Şişeleme Hattı

SBOM / CVE / Patch

Çıktı: Vulnerability Decision

Ad Soyad: Ala ALSAID ALI | Grup: GÜNDÜZ B | Tarih: 06.11.2026

Kavram: **SBOM** = yazılım malzeme listesi · **CVE** = açığın kayıt no'su · **CVSS** = ciddiyet (0–10). Bir CVE sizi etkiler mi? Üç şart: bileşen **var**, sürüm **etkileniyor**, açık **ulaşılabilir**.

Verilen zafiyet kaydı

Bileşen	Component X (PLC firmware kütüphanesi)
Sürüm	2.4
CVE	CVE-XXXX-XXXX
Önem	Critical (CVSS 9.8)
Yama	Mevcut

Görev — karar akışı

1. Bu CVE sizi gerçekten etkiliyor mu? (üç şartı kontrol edin)

   Bileşen var mı: Evet (Makinedeki PLC'de Component X kütüphanesi var). , **Sürüm etkileniyor mu:** Evet (Makinede kullanılan v2.4 sürümü zafiyetli). **Açık ulaşılabilir mi:** Evet (PLC'nin ağ/servis bağlantısı açıksa 3 şart sağlanır ve etkiler)

2. Üretimi hemen durdurur musunuz? Neden / neden değil?

   Hemen durdurulmaz. Bağımsız Safety PLC çalışmaya devam ettiği için fiziksel tehlike yoktur; ağ erişimi izole edilerek planlı duruşta yama yapılır.

3. Yamayı doğrudan mı uygularsınız, önce test mi? Nerede test?

   Önce test edilir. Canlı makine üzerinde denenmez; test laboratuvarında veya yedek test PLC'sinde test uygulanır.

4. Bu yama bir safety validation etkiliyor mu? Nasıl anlarsınız?

   Evet, etkileyebilir. PLC bellenimi (firmware) değiştiği için emniyet duruş süreleri ve STO fonksiyonları test edilerek doğrulanır.

5. Yama mümkün değilse compensating control (telafi edici önlem) ne olur?

PLC'nin dış ağ erişimi kapatılır (air-gap), Firewall üzerinde IP kısıtlaması yapılır ve ağ trafiği IDS ile izlenir.

Bu föyün çıktısı **Vulnerability Decision** → Evidence Pack **EP 09 · 10 · 11** başlığına oturur.

LABORATUVAR 6 · GENEL SÜRÜM · Şişeleme Hattı

CRA Incident Simulation

Çıktı: Incident Workflow

Ad Soyad: Ala ALSAID ALI | Grup: GÜNDÜZ B | Tarih: 06.11.2026

Senaryo: Saat **10:15**. Servis hesabında yetkisiz erişim tespit edildi. PLC konfigürasyonu değişmiş olabilir. Makine hâlâ çalışıyor. Vardiya sorumlusu sizsiniz.

Kavram: Bir olayda en değerli iki şey **zaman** ve **kanıt**tır. CRA'nın 24s / 72s / 14 gün yükümlülükleri, iyi bir müdahale akışının doğal kilometre taşlarıdır — ezber değil.

Görev — zaman çizgisini doldurun

1 **10:15 — ilk 15 dk:** Kimi ararsınız? İlk üç eyleminiz?

Aranan: OT/IT Güvenlik Sorumlusu ve Vardiya Amiri. İlk 3 Eylem: 1) Servis hesabının dış erişimini kes. 2) Makinenin fiziksel emniyet durumunu doğrula. 3) Mevcut PLC konfigürasyonu ve log snapshot'ını al.

2 **İlk 2 saat:** Emniyet güvende mi? Neyi korursunuz (kanıt!)? Hangi hesap kapatılır?

Emniyet Durumu: Safety PLC bağımsız olduğundan emniyet güvendedir. Korunan Kanıt: PLC hafıza dökümü, network logları ve oturum kayıtları. Kapatılan Hesap: Yetkisiz erişim tespit edilen "Servis Hesabı".

3 **24 saat — CRA erken uyarı:** Hangi bilgi hazır olmalı?

4 Olay zamanı, etkilenen cihaz (LUNA 1000 PLC) ve tespit edilen yetkisiz erişim türü içeren ön bildirim raporlanır.

72 saat — CRA bildirim: Kök neden, etki, önlem — kim ne yapıyor?

5 Kök Neden: Servis hesabı kimlik bilgisinin sızdırılması. Etki: Yazılımsal parametre değişimi (fiziksel hasar yok). Önlem & Görev: IT ekibi MFA zorunluluğu getirir, OT ekibi onaylı PLC yedeğini yükler.

14 gün — son rapor: Hangi loglar/kayıtlar korunmuş olmalı?

Güvenlik duvarı logları, Jump Server oturum kayıtları, PLC olay kayıtları ve adli analiz raporu saklanır.

En sık hata: "Resetleyip devam edelim" — o düğme, kanıtı sonsuza dek siler. Önce emniyet, hemen sonra kanıt.

Bu föyün çıktısı **Incident Workflow** → Evidence Pack **EP 13 Incident Response** başlığına oturur.

LABORATUVAR 7 · GENEL SÜRÜM · Şişeleme Hattı

AI Safety Challenge

Çıktı: AI Fail-Safe Decision

Ad Soyad: Ala ALSAID ALI | Grup: GÜNDÜZ B | Tarih: 06.11.2026

Kavram — Prediction ≠ Safety: Yapay zekâ bir karar üretir; güvenliği garanti eden mimari YZ'nin **dışında** tanımlanmalıdır.
Araçlar: fail-safe · human override · monitoring · confidence threshold · fallback.



Görev — üç başarısızlıkta güvenli davranış

1 **Model yanlış sınıflandırdı:** Kusurlu parçaya OK verdi. Sistem ne yapmalı? İkinci kontrol / insan onayı var mı?

Fiziksel lazer/sensör ölçümü ikincil kontrol olarak devreye girer; hatalı parça operatör onayına yönlendirilir (*Human Override / Fallback*).

2 **Girdi manipüle edildi:** Kamera verisi bozuk/sahte. Nasıl fark edilir? Şüpheli girdide ne yapılır?

Görüntüde parazit/donma tespiti (*Monitoring*) yapılır; şüpheli durumda konveyör parçayı reddeder veya durur (*Fail-Safe*).

3 **Confidence düştü:** Model "emin değilim" diyor. Eşik ne olmalı? Altında: dur / insana sor / fallback?

Eşik %85 olarak belirlenir; tahmin bu değerin altında kaldığında sistem parçayı ayırır veya insana sorar (*Confidence Threshold*).

Karar tablosu — AI Fail-Safe Decision

Başarısızlık	Tanımladığınız güvenli davranış (hangi kavramla?)
Model yanlış sınıflandırdı	Lazer sensörle ikincil fiziki kontrol ve manuel durdurma (*Human Override / Fallback*).
Girdi manipüle edildi	Görüntü donma/bozulma tespiti yapılıp hattın güvenli duruşa geçmesi (*Fail-Safe / Monitoring*).
Confidence düştü	%85 eşik altı tahminlerde konveyörün parçayı ayırması (*Confidence Threshold / Fallback*).

Bu föyün çıktısı **AI Fail-Safe Decision** → Evidence Pack **EP 03 + EP 15** başlığına oturur.